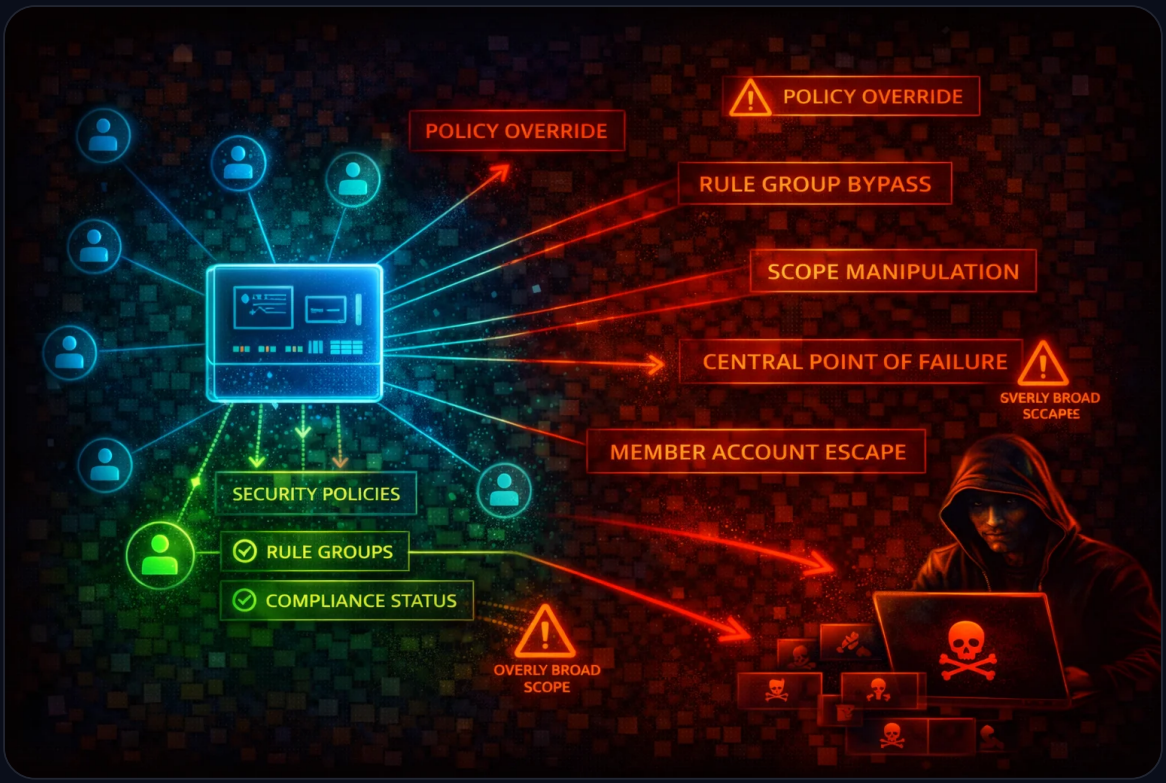


AWS Firewall Manager

Security

MANAGEMENT

AWS Firewall Manager is a centralized security management service that lets you configure and deploy firewall rules and protections across multiple accounts and resources in an AWS Organization. It manages WAF, Shield Advanced, VPC Security Groups, Network ACLs, Network Firewall, Route 53 Resolver DNS Firewall, and third-party firewalls.

HIGH	Org-wide	WAF/SG/NF/DNS	Orgs + Config
Risk Level	Scope	Policy Types	Requires

📋 Service Overview

Centralized Policy Management

Firewall Manager enforces security policies across all accounts in an AWS Organization. Policies are automatically applied to new accounts and resources as they are added.

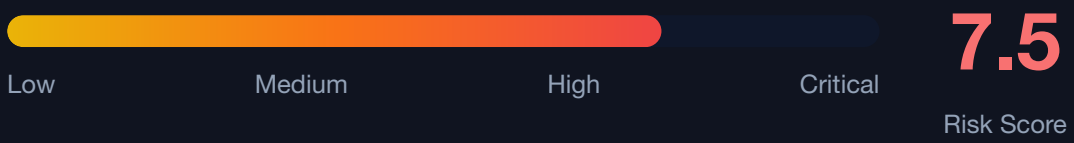
Attack note: Compromising the FMS administrator account grants the ability to weaken or delete security policies across the entire organization in a single operation.

Auto-Remediation and Scope Control

Policies can automatically remediate non-compliant resources. Scope is controlled via account inclusion/exclusion maps, resource tags, and resource types.

Attack note: An attacker with fms:PutPolicy can modify a policy's scope or disable remediation, leaving resources unprotected without triggering obvious alerts.

Security Risk Assessment



Firewall Manager is an organization-wide security control plane. Compromise of the FMS administrator account can silently remove WAF rules, security group restrictions, and Network Firewall protections across every account in the organization.

⚔️ Attack Vectors

Policy Manipulation

- Disable RemediationEnabled to stop auto-fix
- Change IncludeMap/ExcludeMap to narrow scope
- Switch policy rules to permissive configurations
- Delete critical policies with fms:DeletePolicy
- Narrow admin scope to push policies OUT_OF_ADMIN_SCOPE

Administrative Takeover

- fms:PutAdminAccount to register rogue administrator
- fms:AssociateAdminAccount to designate attacker as admin
- fms:DeleteNotificationChannel to suppress alerts
- fms:DisassociateAdminAccount to remove legitimate admin
- Modify admin scope to limit legitimate admin visibility

⚠️ Misconfigurations

Policy Scope Issues

- RemediationEnabled set to false
- Overly broad tag exclusions leaving resources unprotected
- IncludeMap limited to subset of accounts
- Policies created only in one Region
- DeleteUnusedFMManagedResources set to false

Operational Gaps

- AWS Config not enabled in all accounts/Regions
- No SNS notification channel configured
- Security group policies in audit mode only
- WAF policies using COUNT instead of BLOCK
- Third-party firewall integration not verified

🔍 Enumeration

Identify FMS Administrator Account

```
aws fms get-admin-account
```

List All FMS Policies

```
aws fms list-policies
```

Get Full Policy Details

```
aws fms get-policy \
  --policy-id
a1b2c3d4-5678-90ab-cdef-
EXAMPLE11111
```

List Member Accounts Under FMS

```
aws fms list-member-
accounts
```

Check Notification Channel

```
aws fms get-notification-
channel
```

📈 Privilege Escalation

fms:PutPolicy - Weaken Org Security

- Modify existing policies to disable remediation
- Narrow scope to exclude target accounts
- Change managed service data to permissive rules
- Remove security controls across all in-scope accounts

fms:DeletePolicy - Remove Protections

- Delete Firewall Manager policies at scale
- Remove centrally managed WAF/SG/NF configurations
- Combine with fms:DeleteNotificationChannel to go unnoticed
- fms:AssociateAdminAccount to install own admin account

🔗 Persistence

Weakening Policies

- Set RemediationEnabled to false on all policies
- Add broad tag exclusions to bypass protection
- Narrow IncludeMap to exclude critical accounts
- Delete notification channel to suppress alerts
- Switch WAF rules from BLOCK to COUNT

Administrative Takeover

- Register rogue FMS administrator account
- Disassociate legitimate admin account
- Modify admin scope to limit visibility
- Delete critical policies across organization
- Disable auto-remediation silently

🛡️ Detection

High-Impact CloudTrail Events

- PutPolicy - policy created or modified
- DeletePolicy - policy deleted
- AssociateAdminAccount - admin account changed
- DisassociateAdminAccount - admin removed
- PutAdminAccount - admin account added

Compliance Monitoring

- DeleteNotificationChannel - alerts suppressed
- ListComplianceStatus - check policy compliance
- Policy scope changes via IncludeMap/ExcludeMap
- RemediationEnabled toggle on policies
- New FMS administrators via list-admin-accounts-for-organization

💻 Exploitation Commands

Delete a Critical Policy

```
aws fms delete-policy \
  --policy-id a1b2c3d4-5678-90ab-cdef-EXAMPLE11111
```

Delete Notification Channel

```
aws fms delete-notification-channel
```

Disassociate Admin Account

```
aws fms disassociate-admin-account
```

List All Admins for Recon

```
aws fms list-admin-accounts-for-organization
```

Check Compliance Status

```
aws fms list-compliance-status \
  --policy-id a1b2c3d4-5678-90ab-cdef-EXAMPLE11111
```

📜 Policy Examples

✗ Dangerous - Broad FMS Exclusion, No Remediation

```
{
  "RemediationEnabled": false,
  "ExcludeResourceTags": true,
  "ExcludeMap": {
    "ACCOUNT": ["111111111111", "222222222222"]
  }
}
```

Remediation disabled, accounts excluded, and resources excluded by tag. Non-compliant resources are never fixed.

✓ Secure - Full Scope, Remediation Enabled

```
{
  "RemediationEnabled": true,
  "ExcludeResourceTags": false,
  "DeleteUnusedFMManagedResources": true,
  "IncludeMap": {}
}
```

Remediation enabled, no exclusions, all accounts covered, orphaned resources cleaned up.

Defense Recommendations

Restrict FMS Administrative Permissions

Limit fms:PutPolicy, fms:DeletePolicy, fms:AssociateAdminAccount to minimum principals. Use SCPs to block member account FMS writes.

Enable Auto-Remediation on All Policies

Set RemediationEnabled: true on every Firewall Manager policy. Audit-only mode is useful during rollout, but production must enforce.

Configure SNS Notification Channel

Use aws fms put-notification-channel to send compliance findings to an SNS topic monitored by your security team.

```
aws fms put-notification-channel \
  --sns-topic-arn arn:aws:sns:us-
east-1:123456789012:fms-alerts \
  --sns-role-name FMSSNSRole
```

Enable AWS Config in All Accounts

FMS depends on AWS Config to detect resource compliance. Ensure Config is enabled in every account and Region.

Monitor FMS API Calls with CloudTrail

Alert on PutPolicy, DeletePolicy, AssociateAdminAccount, DisassociateAdminAccount, and DeleteNotificationChannel.

Apply Policies Across All Regions

FMS policies are Regional. Create policies in every Region where you have resources, or deny resource creation in uncovered Regions.

AWS Firewall Manager Security Security Card

Always obtain proper authorization before testing